WINDOWS-FIRST / SELF-HOSTED / BUILD-READY

Self-Hosted LAN and Internet File Finder

Product, architecture, security and delivery plan for a metadata-only multi-computer file finder.

Recommended baseline

Main-PC coordinator | LAN + private VPN | Tauri/Rust agent

Fastify/TypeScript API | PostgreSQL 16+

Prepared: 29 August 2026

Pilot topology: one main computer and two internet-connected sub-computers

DEPLOYMENT PRINCIPLE

No Docker on employee desktops. The main computer hosts the coordinator and database. Remote computers connect through a private VPN overlay; file contents never leave the owning computer.

Contents

1. Executive Decision

Build a Windows-first file finder in which a main computer coordinates metadata from authorised folders on local and remote computers. Office computers use the LAN; remote computers use a customer-managed WireGuard or Tailscale-style private VPN. The same device identity, security model and event sequence apply on both routes.

> **Product statement**
> Search once on the main computer and locate a file across every authorised computer, whether connected by LAN or private VPN, without copying file contents to a central cloud.

Included in pilot	Explicitly deferred
Device enrolment and revocation	File-content indexing, preview and download
Selected-folder metadata indexing	Direct public coordinator exposure and hosted relay
Filename/path search and filters	Network shares, removable drives and cloud placeholders
LAN, VPN and automatic connection modes	macOS, Linux and multi-office federation
Presence and last-known locations	OCR, semantic search, SSO and complex RBAC
Safe reveal on the owning computer	Arbitrary commands and remote process execution

Pilot success

- The main computer runs the coordinator, database and search application and may also index its own local files.
- Two sub-computers connect from separate internet locations through a private VPN and remain distinct, revocable devices.
- Metadata changes normally become searchable within 10 seconds on both LAN and stable VPN connections.
- The main computer shows filename, path, size, date, owning device, route and status, but never receives file content.
- A reveal request is confirmed and executed only in the active session of the file-owning computer.

2. Deployment Architecture

Component	Location	Responsibility	Docker
Desktop/tray application	Every user PC	Search UI, settings, notifications and local reveal	No
Windows agent service	Every indexed PC	Scan, watch, journal, reconcile, heartbeat and validate commands	No
Coordinator API	Main computer	Authentication, ingestion, search, commands and administration	Optional
PostgreSQL 16	Main computer	Authoritative metadata, identity, events and audit records	Optional
Private VPN	Customer network	Private internet route between remote devices and coordinator	No product container

Network topology

> **LAN route**
> Office agent -> HTTPS/mTLS over a private LAN address -> coordinator on the main computer -> PostgreSQL on localhost.

Internet route
Remote agent -> outbound private VPN tunnel -> HTTPS/mTLS over a VPN address -> coordinator on the main computer -> PostgreSQL on localhost.

- PostgreSQL listens on localhost only and is never reachable from LAN, VPN or public interfaces.
- The coordinator listens only on administrator-selected LAN and VPN interfaces.
- The installer creates firewall rules restricted to configured LAN subnets and the VPN interface.
- The product does not configure router port forwarding, public NAT traversal or a hosted relay.
- If the main computer is offline, agents journal changes and resume from the last acknowledged sequence after reconnection.

Connection profiles

Profile	Behaviour	Use case
LAN_ONLY	Connect only to the configured private LAN endpoint.	Computers that never leave the office
VPN_ONLY	Connect only to the configured private VPN endpoint.	Permanently remote computers
AUTO_LAN_VPN	Prefer LAN, fall back to VPN, and migrate only after current acknowledgements complete.	Laptops moving between office and remote networks

A route switch preserves the same device ID, client certificate, local journal and sequence counter. Only one logical agent session may be active, preventing duplicate devices and duplicate event streams.

3. Installation And Operating Modes

Package	Installed processes	Primary result
Desktop installer	Windows agent service, Tauri tray/search app and elevated root helper	Normal signed installation with no SDK or Docker dependency
Native coordinator	Fastify service, private Node runtime and dedicated PostgreSQL service	Main-PC installation with selected data and backup directories
Docker Compose	Coordinator and PostgreSQL containers with persistent volumes	Equivalent advanced deployment for Docker-capable administrators

Recommended installation flow

- The administrator installs the native coordinator on the main computer and selects LAN and VPN interfaces, data directory and backup directory.
- The installer provisions PostgreSQL, creates the first administrator and accepts a company certificate or generates a pinned fallback certificate.
- The administrator configures the main computer firewall for the selected LAN subnet and VPN interface only.
- The administrator creates a short-lived, single-use device enrolment bundle containing the coordinator identity fingerprint.
- Each sub-computer installs the service and tray application, enters the LAN and/or VPN endpoint, selects a connection profile, and enrols.
- An elevated helper grants the restricted service account read/list access to explicit local NTFS roots.
- The service starts watching, records a sequence watermark, performs a throttled scan, uploads bounded snapshot chunks and replays later events.

4. Functional Specification

Capability	Required behaviour	Acceptance condition
Enrolment	One-time code binds one device certificate to the organisation.	Expired, reused and revoked credentials fail.
Folder selection	Only elevated, explicit local NTFS roots are indexed.	No record outside an authorised root reaches the coordinator.
Initial scan	Recursive scan streams bounded chunks and reports progress.	One million entries do not cause unbounded memory use.
Live changes	Create, modify, rename and delete events update the index.	A normal change is visible within 10 seconds.
Reconciliation	Periodic snapshots repair missed watcher events.	Forced event loss converges to the correct state.
Search	Ranked filename/path search with structured filters.	p95 remains below 500 ms at pilot scale.
Connectivity	LAN, VPN and automatic fallback preserve one device session.	Network changes do not duplicate devices or events.
Presence	Heartbeat and route determine online, stale and offline state.	Transitions follow documented thresholds.
Reveal	A signed request is confirmed on the owning active session.	Explorer never opens on the wrong device or outside an authorised root.
Administration	Admins rename, pause, revoke and inspect devices.	Revoked devices cannot ingest or receive commands.

Result presentation

> **Example**
> project_report.pdf | PC-02 | VPN / Online | D:\College\Projects | PDF | 471 KB | Modified 29 Aug 2026 | Reveal on PC-02 | Copy path

Exact filename, exact stem, prefix, token, substring, fuzzy filename and relative-path matches define ranking order. Device name, route, online state and path remain visually prominent.

5. Agent, Data And Indexing Contracts

Agent boundaries

- The Windows service owns machine identity, scanning, watching, journaling, reconciliation and network connectivity.
- The service runs as NT SERVICE\FileFinderAgent with explicit read/list ACLs on selected roots.
- The tray application owns user login, search, status, notifications and interactive reveal confirmation.
- Service and tray communicate over an ACL-protected named pipe using a closed schema.
- Local fixed NTFS volumes are supported. Reparse points, junctions, symlinks, cloud placeholders, network shares and removable media are excluded.

Core data model

Entity	Key fields and purpose
organisations	Tenant boundary and organisation settings.
users / refresh_sessions	Individual ADMIN or MEMBER accounts and rotating session state.
devices / device_certificates	Machine identity, OS, state, active route, certificate and last seen.
indexed_roots	Explicit canonical NTFS roots, enabled state and reconciliation checkpoint.

Entity	Key fields and purpose
files	Stable file ID, original and normalized names, root-relative path, extension, size, modified time and tombstone.
event_receipts	Event UUID, per-device sequence, operation and acknowledgement evidence.
reconciliation_sessions	Snapshot watermark, root, state and completion generation.
device_commands	Signed reveal/open request, expiry, delivery and typed outcome.
audit_log / backup_history	Append-only security and operational evidence.

Indexing protocol

- Use NTFS volume serial plus FILE_ID_INFO as the stable file identity; store root plus relative path for display and search.
- Use Unicode NFKC and invariant lowercase normalization while preserving original casing.
- Assign every event a UUID and monotonically increasing per-device sequence.
- Limit batches to 1,000 records and 4 MiB of uncompressed JSON; flush within two seconds under normal activity.
- Use UPSERT for create, modify and stable-ID rename; use DELETE for tombstones.
- Return the latest contiguous acknowledged sequence. A gap returns 409 SEQUENCE_GAP with the expected sequence.
- Bound the local SQLite WAL journal at 2 GiB or 2 million unacknowledged events; overflow marks roots dirty and triggers reconciliation.
- Retain tombstones and event evidence for 30 days, command records for 90 days, and audit records under configurable policy.
- Keep file hashes nullable and disabled in the normal scan path.

Reconciliation

Reconciliation uses create-session, bounded chunk upload and atomic completion operations. The watcher starts first and records a sequence watermark. The service uploads the snapshot, atomically tombstones unseen rows for that root, and then replays journal events after the watermark.

6. Service Interfaces And Command Flow

Interface	Method/event	Purpose
/api/v1/auth/login	POST	Issue short-lived user access and rotating refresh session.
/api/v1/users	GET/POST/PATCH	Administer individual local accounts.
/api/v1/enrolments	POST	Create a short-lived device enrolment bundle.
/api/v1/devices/enrol	POST	Exchange enrolment code and CSR for device identity.
/api/v1/agent/events/batch	POST	Ingest ordered, idempotent metadata events.
/api/v1/agent/reconciliations	POST	Create and complete bounded snapshot sessions.
/api/v1/files/search	GET	Ranked filters with opaque cursor pagination.
/api/v1/devices	GET/PATCH	List, rename, pause or revoke devices.
/api/v1/commands	POST	Create a signed, expiring reveal/open command.
Agent WebSocket	Heartbeat/event	Presence, route, command delivery and acknowledgement.

Safe reveal sequence

- The requesting user selects an indexed file and requests reveal.
- The coordinator validates organisation, user role, file ownership and device presence.
- The coordinator creates a 60-second Ed25519 JWS command containing command ID, file ID, target device, requester and nonce.
- The service verifies signature, expiry, target, replay state and current enabled root containment.
- The service forwards the request to the active tray session through the named pipe.
- The local user accepts or declines a notification naming the requester, file and path.
- Explorer opens only after acceptance; the coordinator records ACCEPTED, USER_DECLINED, NO_INTERACTIVE_SESSION, DEVICE_OFFLINE, PATH_NOT_FOUND, OUTSIDE_ROOT or EXPIRED.

7. Security And Privacy Baseline

Control	Minimum implementation	Threat addressed
Transport	TLS on LAN and VPN; reject plaintext.	Interception and credential theft
Internet route	Customer-managed private WireGuard/Tailscale network.	Unnecessary public exposure
Device identity	Per-device key and client certificate with revocation.	Shared-secret compromise
Server identity	Company certificate or administrator-pinned fallback.	Impersonation and first-use attacks
User sessions	Argon2id, 15-minute access tokens and rotating refresh sessions.	Account takeover and replay
Authorised roots	Elevated ACL grant, canonical path and handle-based containment.	Traversal and scope escape
Commands	Signed, expiring, single-use, closed-schema messages.	Replay and remote command execution
Tenant boundary	organisation_id on every tenant row and scoped repositories.	Cross-organisation disclosure
Firewall	LAN subnet and VPN interface allowlists only.	Public attack surface
Audit	Append-only admin, authentication and command outcomes.	Undetected misuse
Backups	Nightly encrypted backups and monthly restore tests.	Loss or theft of metadata

Privacy fact
Filenames and folder paths can contain employee, patient, client or project names. Metadata is confidential even though file contents never leave the owning computer.

8. Technology And Repository Design

Layer	Choice	Implementation note
Desktop	Tauri 2 + React + TypeScript	Bundled search/tray interface and safe Rust bridge.
Agent core	Rust	Windows scanner, watcher, SQLite journal and mTLS client.
Coordinator	Node.js + TypeScript + Fastify	Schema-first API and WebSocket broker.
Database	PostgreSQL 16+	B-tree plus pg_trgm search at pilot scale.
Contracts	Versioned JSON Schema	Generate TypeScript and Rust models; verify golden fixtures.
Agent state	SQLite WAL	Durable bounded queue, checkpoints and replay evidence.
Packaging	WiX bootstrapper / signed binaries	Native services and embedded runtime; no desktop SDK.

Layer	Choice	Implementation note
Internet	WireGuard/Tailscale-style VPN	Private addresses; no provider-specific API dependency.
Observability	Structured local logs + health	Path redaction enabled by default.

Search design

- Use PostgreSQL pg_trgm and B-tree indexes before introducing a separate search service.
- Apply device, root, extension, size, date and presence filters before cursor pagination.
- Rank exact filename, exact stem, prefix, token, substring, fuzzy filename and finally relative-path matches.
- Use an opaque cursor containing score, normalized filename and file ID; do not use offset pagination for normal search.
- Target p95 below 500 ms at 2 million active records and 20 concurrent clients on a 4-core, 16-GB RAM, SSD main computer.

9. Delivery Roadmap For Two Developers

Phase	Timing	Primary work	Exit gate
1. Foundation	Week 1	Threat model, monorepo, contracts, CI, Windows service and IPC spikes.	Boundaries and protocol approved.
2. Identity	Weeks 2-3	Accounts, TLS, device CA, enrolment, revocation, audit and interface binding.	Secure desktop-to-coordinator connection.
3. Agent	Weeks 3-5	Service, tray, DPAPI, ACL helper, scanner, SQLite journal and progress.	Reliable 100k-file scan.
4. Connectivity	Weeks 5-6	LAN/VPN profiles, fallback, migration, pinning and offline recovery.	One identity survives route changes.
5. Ingestion	Weeks 6-8	Ordered events, idempotency, tombstones, watcher, reconciliation and compaction.	Changes converge after faults.
6. Search	Weeks 8-10	Login, ranking, filters, pagination, device status and administration.	Search latency target passes.
7. Commands	Weeks 10-11	WebSocket, presence, signed commands, confirmation and Explorer reveal.	Safe end-to-end reveal succeeds.
8. Operations	Weeks 11-14	Signed installers, Compose, upgrade, logs, backup and restore.	Both deployment modes install cleanly.
9. Pilot	Weeks 14-17	Two remote computers, outages, security, scale and disaster recovery.	All pilot acceptance gates pass.

Expected delivery is 13-17 weeks for two developers. The range reflects native and Docker coordinator release gates, the service/tray split, dual LAN/VPN connectivity and a real multi-network pilot.

10. Verification And Acceptance

Required verification

- Install the native coordinator and search UI on one clean Windows 11 Pro main computer.
- Install agents on two clean Windows sub-computers located on separate internet connections.
- Join all computers to a private VPN without opening a public coordinator port.
- Verify LAN devices use the LAN endpoint and remote devices use the VPN endpoint.
- Move a sub-computer between office LAN, external internet/VPN, disconnection and LAN again without duplicating its identity or events.

- Shut down the main computer, create changes remotely, restart it and verify complete, duplicate-free recovery.
- Create, modify, rapidly rename, move and delete files; deliberately drop watcher events and verify reconciliation.
- Verify the main computer receives metadata only and cannot preview, download or directly open remote content.
- Request reveal and confirm that only the owning computer shows a prompt and opens Explorer after acceptance.
- Test certificate mismatch and rotation, expired/replayed/wrong-device commands, traversal, junction escape, revocation, token reuse, oversized batches and tenant isolation.
- Generate 100k, 500k, 1M and 2M metadata records and verify bounded memory plus p95 search below 500 ms.
- Restore an encrypted backup onto a clean main computer and recover users, devices, metadata, settings, certificates and audit history.

Pilot acceptance gates

Outcome	Evidence
Install without tooling	Signed packages succeed with no Node.js, Rust, PostgreSQL or Docker on sub-computers.
Private self-hosting	Indexing and search continue without public cloud dependency; no public coordinator port exists.
LAN and internet	Main PC plus two remote PCs remain identified across LAN/VPN route changes.
Correct discovery	Files are found by filename/path and filters with accurate device, route and location.
Reliable convergence	Normal and missed events converge after outages, restarts and reconciliation.
Safe action	Reveal executes only on the owning device, after local confirmation, inside an enabled root.
Recoverability	Offline journal, component restart, encrypted backup and clean restore are demonstrated.
Controlled administration	Admins enrol, pause, revoke and audit; members cannot perform admin actions.

11. Operations, Upgrades And Backup

Topic	Default policy
Main computer	Always-on Windows 11 Pro with stable LAN identity and private VPN membership.
Backup	Nightly encrypted backup; 7 daily and 4 weekly copies; monthly clean restore test.
Agent queue	2 GiB or 2 million events; compact only after acknowledgement or dirty-root reconciliation.
Logs	Structured local logs, path redaction by default and 14-30 day retention.
Health	Database, disk, queue lag, agent versions, route and last-seen state.
Updates	Signed packages and manifests, staged rollout and current/previous minor protocol support.
Schema	Automatic preflight, backup, versioned migrations and documented rollback boundary.
Recovery	New coordinator install, database/config restore, certificate validation and agent reconnection.

12. Assumptions And Definition Of Done

Locked assumptions

- The main computer hosts the coordinator and must stay powered on for live search, ingestion, presence and commands.
- Remote connectivity uses a customer-managed WireGuard or Tailscale-style private network.
- Direct public HTTPS exposure, automatic router configuration, hosted relay and product-managed NAT traversal are out of scope.

- LAN and VPN are transport choices for the same coordinator, organisation, devices and database.
- One organisation is configured per coordinator; all members can search all indexed metadata.
- Root changes require organisation-admin authentication and local Windows elevation.
- Only local fixed NTFS roots are supported in the pilot.
- File contents, previews, downloads, uploads, remote transfers and normal-scan hashes are not sent to the main computer.
- Windows Server 2022 and Windows 11 Pro x64 are supported coordinator hosts; Server 2025 receives compatibility testing.
- Native and Docker coordinator installations use the same schema, protocol, backup format and upgrade tests.

Definition of done

> **Pilot completion**
> The release is done only when one clean main computer and two clean internet-connected sub-computers can be installed without development tooling, operate through LAN and private VPN, converge after faults, search two million metadata records within target latency, execute safe local reveal, and recover from an encrypted backup on a customer-like network.